

MishiPass Security Audit & Remediation Report

Aikido Security AI Code Audit Evidence

Prepared for the #hackthekitty project submission

CURRENT STATUS Retest required before final submission

Project	MishiPass
Security platform	Aikido Security
Evidence source	24 screenshots captured throughout scanning and remediation
Report date	7 July 2026

Submission note

The uploaded evidence demonstrates that vulnerabilities were identified, fixes were generated and merged, and some repository findings were marked solved. However, the latest AI Code Audit screenshot still shows 3 open issues and 0 solved issues while each item is labeled “PR Merged”. This report therefore treats the remediation as merged but not yet verified by Aikido. A final Retest is required before claiming a clean scan.

1. Executive Summary

MishiPass used Aikido Security to assess source code, repository configuration, and the deployed application. The evidence trail documents the scan lifecycle from initial audit through AutoFix review, pull-request merging, repository remediation, and live-domain findings.

AI CODE AUDIT 3 issue groups / 6 subissues initially 2 medium, 1 low issue groups	AUTOFIX / PRS Fixes generated and merged Current audit rows show PR Merged
--	---

REPOSITORY SCAN 5 issues shown at one stage Workflow credential issue later shown Solved	LIVE DOMAIN 3 header issues remain in latest evidence CSP critical, HSTS high, anti-clickjacking medium
---	--

ACTION What to do now — Open the Aikido AI Code Audit and press Retest. Wait until the audit refreshes. The submission-ready result should show the remediated findings as Solved/Resolved rather than only PR Merged. Then rescan the live domain after the three HTTP header findings are fixed.

Submission readiness

AREA	EVIDENCE STATUS	SUBMISSION STATUS
AI Code Audit	Fixes merged; retest not reflected in summary	Needs final Retest
AutoFix remediation	Multiple fix previews and task executions documented	Evidence ready
Repository scan	One workflow issue shown Solved; latest overall count still requires review	Recheck latest scan
Live domain scan	3 security-header issues visible	Fix and rescan

2. Scope and Method

The security review covered three complementary surfaces: application source code, repository and workflow configuration, and the deployed web endpoint. This is stronger evidence than a single scanner screenshot because it demonstrates secure coding review, remediation activity, and operational exposure checks.

SURFACE	WHAT WAS ASSESSED	EVIDENCE IN THIS REPORT
AI Code Audit	Authorization, input validation, sensitive information exposure	Initial findings, AutoFix previews, merged PR status
Repository / SAST	GitHub Actions permissions and credential persistence	Repository issue list and solved workflow finding
Domain security	Response-header protections on the deployed site	CSP, HSTS and anti-clickjacking findings

Audit lifecycle documented

- AI audit started and completed.
- Initial issue groups and detailed subissues reviewed.
- Aikido AutoFix previews and diffs inspected.
- Fix tasks executed and pull requests created/merged.
- Repository scan findings reviewed, including GitHub Actions hardening.
- Live domain scanned for deployment-level security headers.
- Current audit state captured for final verification planning.

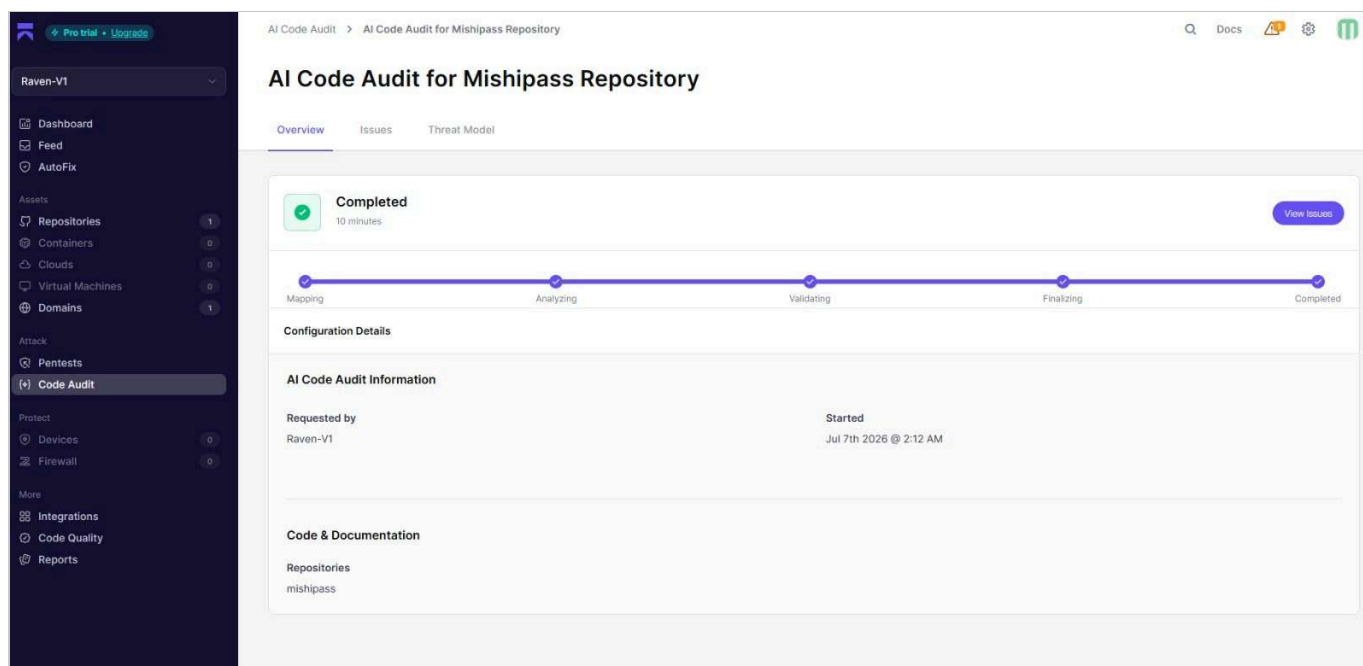


Figure 1. AI Code Audit completed for the MishiPass repository.

3. Initial Findings

The initial AI Code Audit grouped the findings into 3 open issues containing 6 subissues. The issue summary showed 2 medium-severity groups and 1 low-severity group.

FINDING	SEVERITY	AFFECTED AREA	RISK THEME
Improper Access Control	Medium	missingAlerts.ts	Privacy / authorization
Improper Input Validation	Medium	transferRequests.ts	Injection / untrusted input
Exposure of Sensitive Information	Low	auth.ts	Account enumeration / information exposure

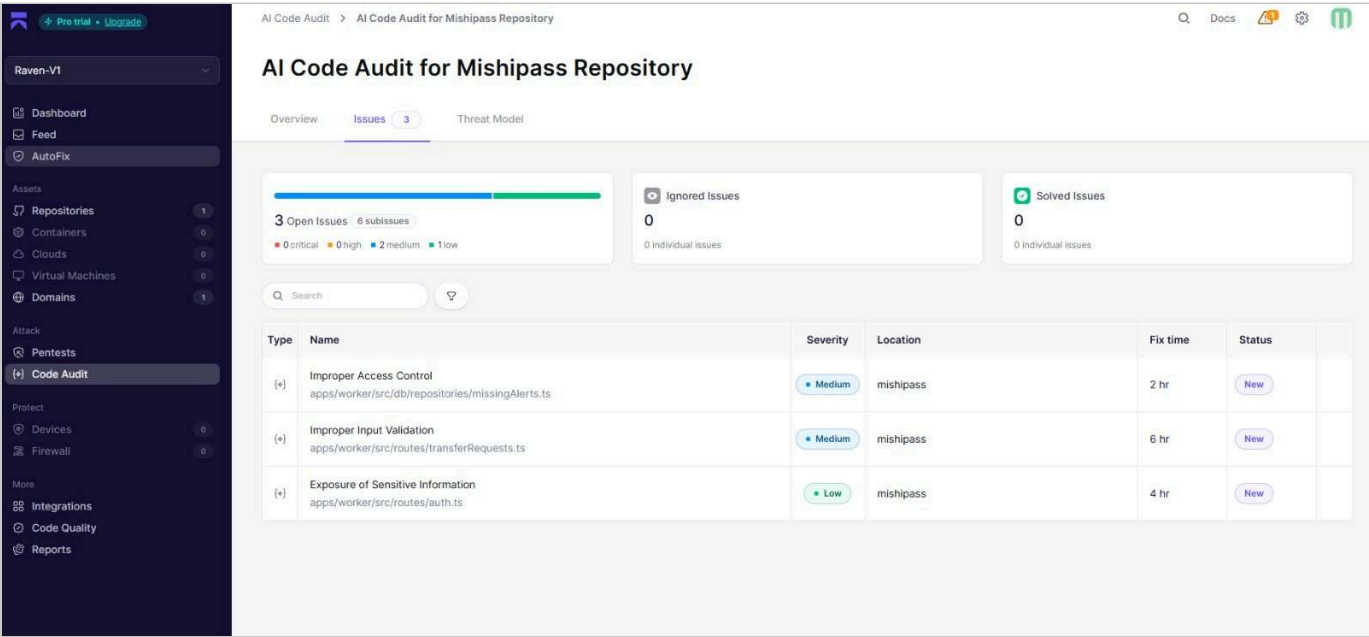


Figure 2. Initial AI Code Audit issue summary: 3 open issues and 6 subissues.

Detailed AutoFix queue

The AutoFix queue exposed the concrete subissues behind the grouped findings:

- Public Recovery Board exposes missing alerts after owners opt out (Medium).
- Stored HTML injection in transfer-request notification emails (Medium).
- Stored HTML injection in outbound adoption-transfer emails via cat name (Medium).
- Stored HTML injection in transfer-acceptance emails via unescaped cat name (Medium).
- Registration endpoint leaks whether an email is already registered (Low).
- Public login timing side-channel reveals whether an owner email exists (Low).

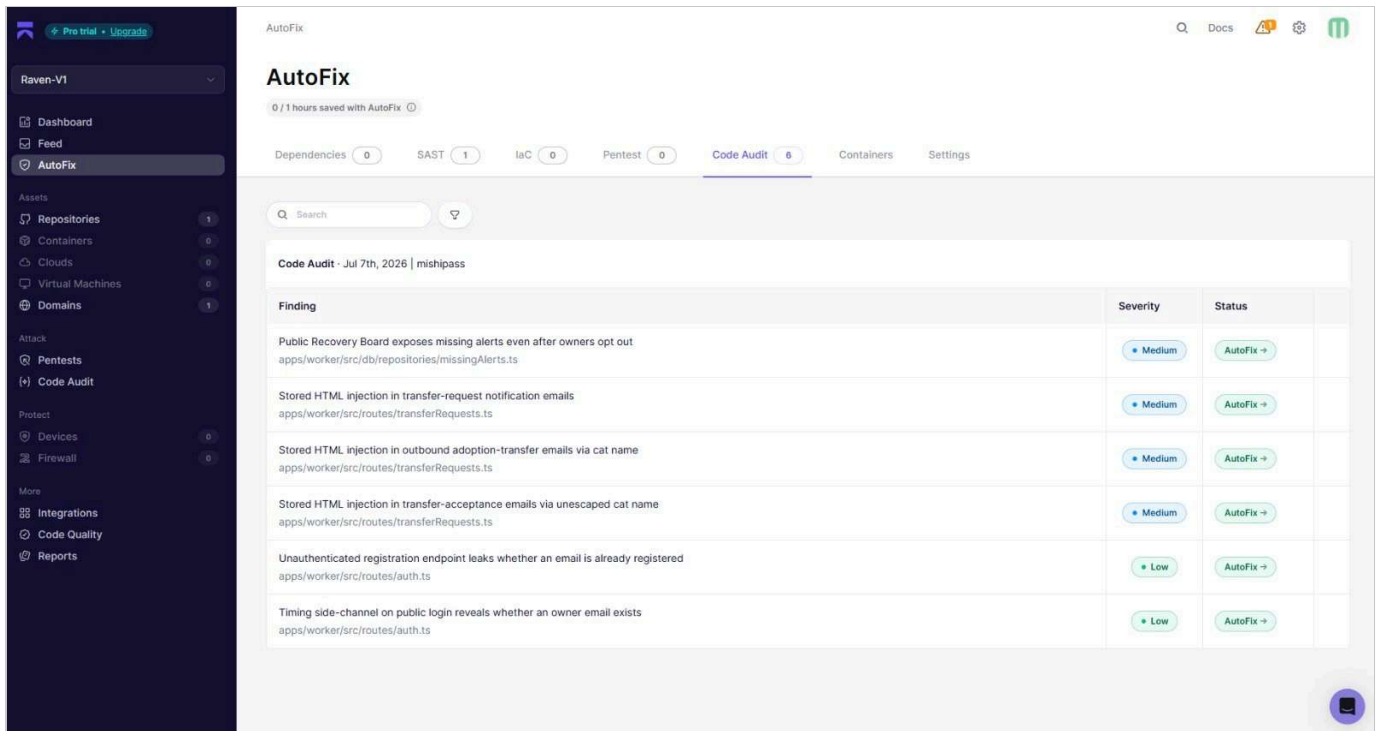


Figure 3. Six detailed code-audit findings queued for AutoFix.

4. Remediation Process and Evidence

The screenshots document a repeated remediation cycle: inspect the finding, review the proposed fix, inspect the generated diff, execute the AutoFix task, merge the resulting pull request, and return to the audit for verification.

4.1 AutoFix review

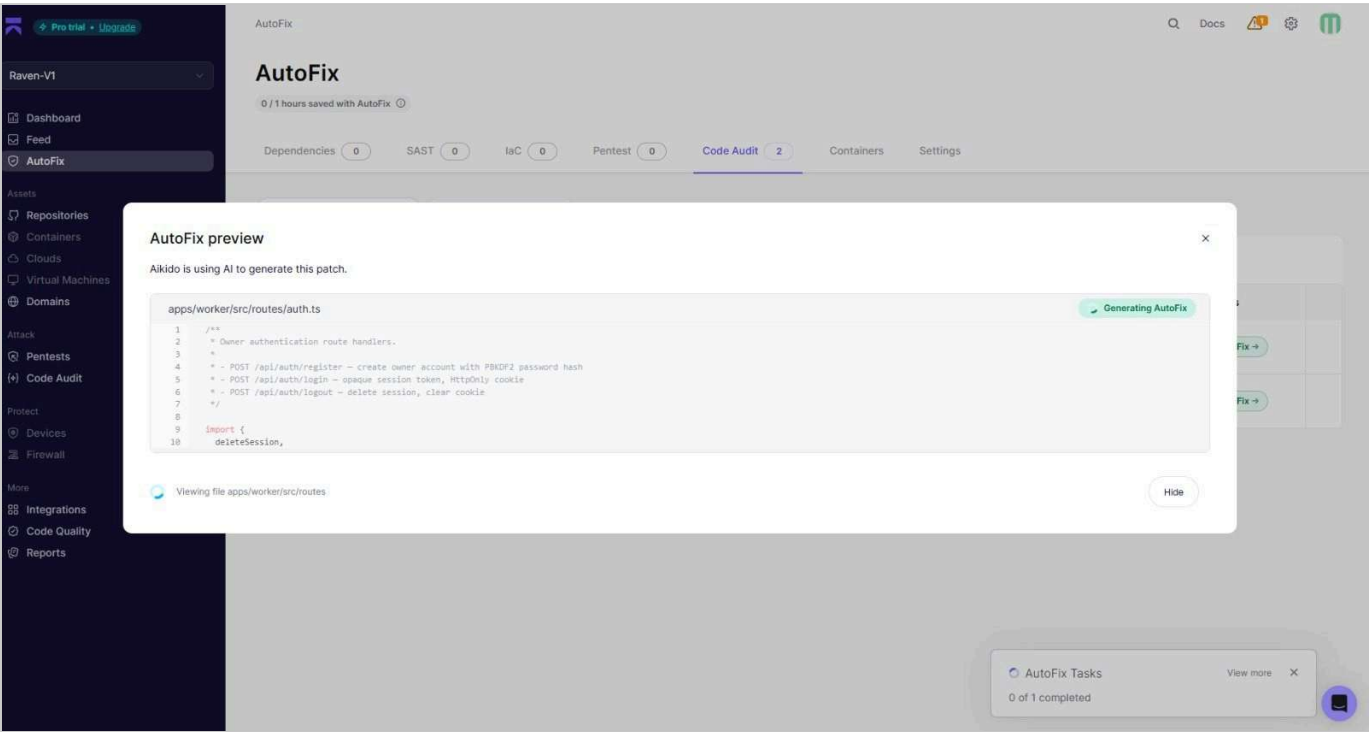


Figure 4. Example Aikido AutoFix preview before applying a code change.

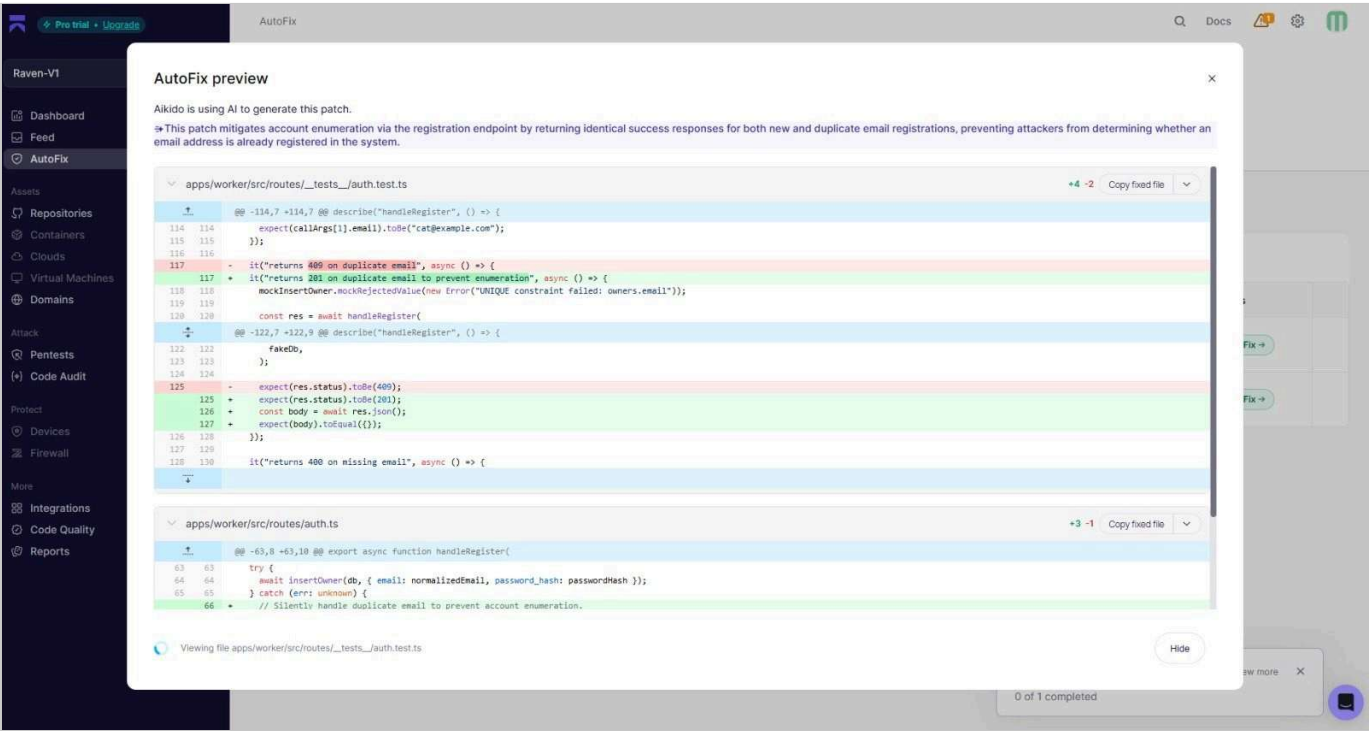


Figure 5. Generated code diff reviewed before remediation.

4.2 Fix execution and pull-request workflow

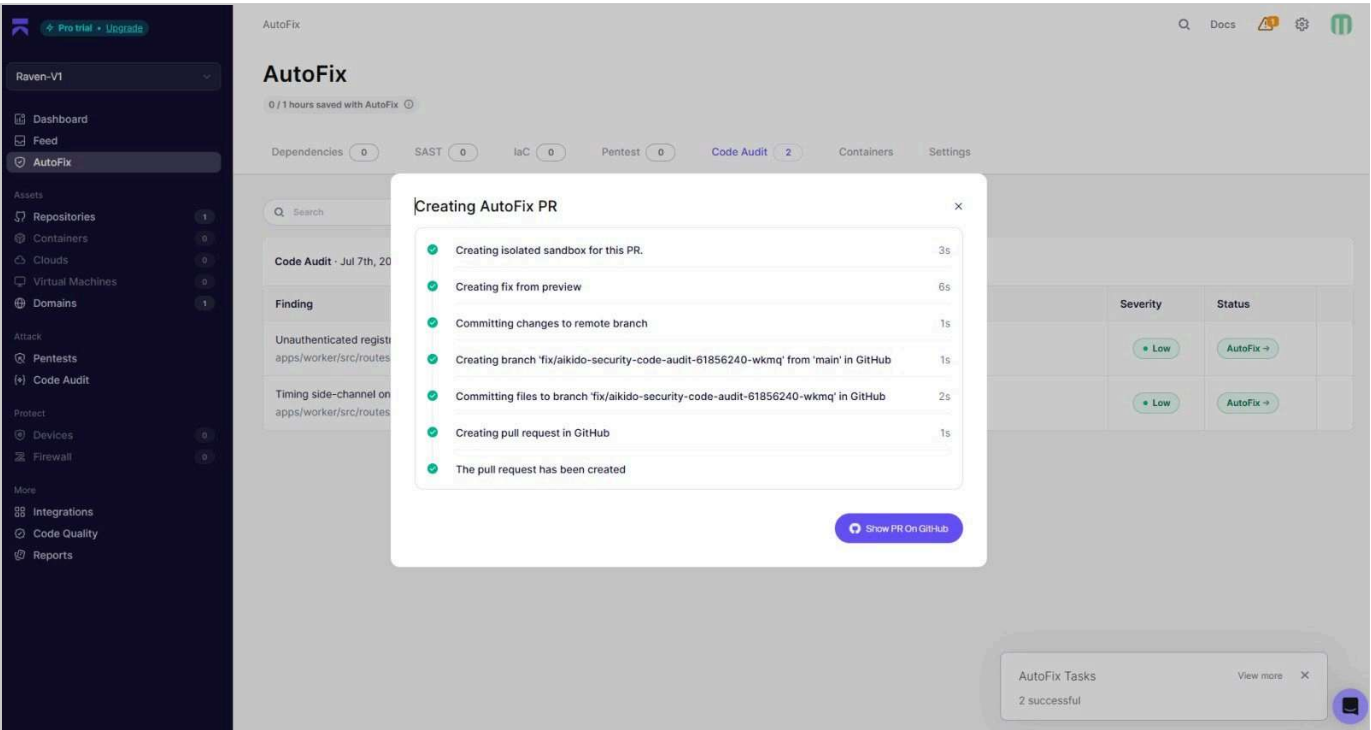


Figure 6. AutoFix task execution in progress.

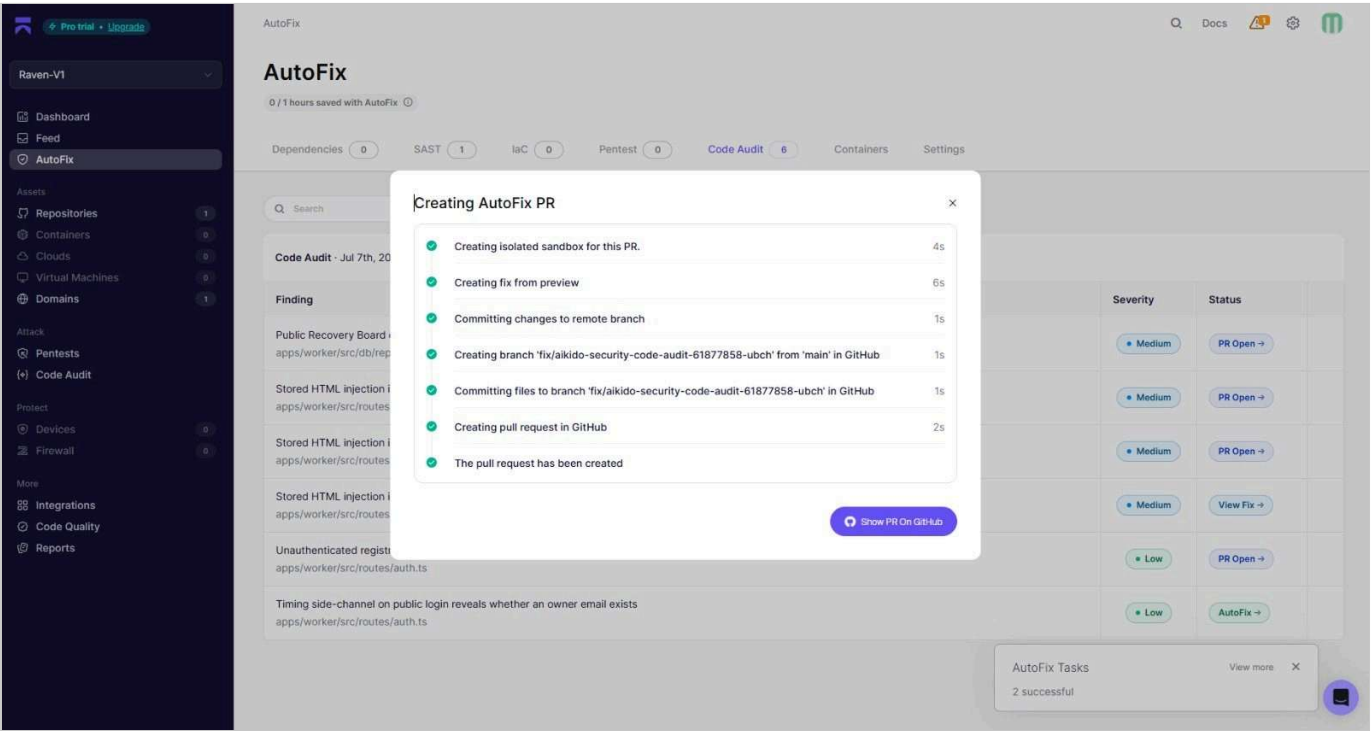


Figure 7. Additional AutoFix task execution during the remediation cycle.

Remediation outcome captured

The latest code-audit evidence shows each of the three grouped findings with the status “PR Merged”. This is evidence that the fixes were integrated into the repository. It is not, by itself, final proof that Aikido has re-tested and closed the findings.

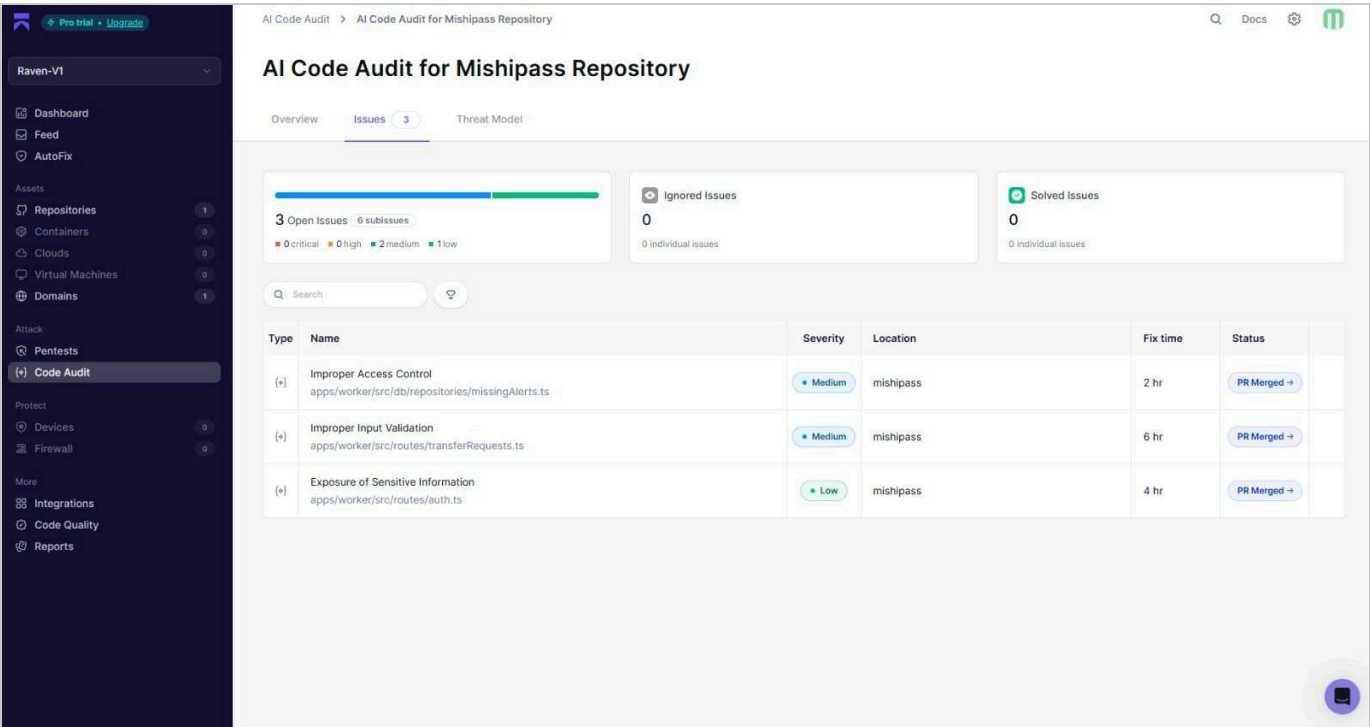


Figure 8. All three grouped code-audit findings shown with PR Merged status.

IMPORTANT Verification gap — the summary in the same screenshot still shows 3 Open Issues and 0 Solved Issues. Aikido must re-run verification before the report can honestly state that the code audit is clean.

5. Repository and Workflow Security

Aikido also scanned repository configuration and GitHub Actions. At one stage, the repository view showed 5 issues: 3 medium and 2 low. This added supply-chain and CI/CD hardening to the application-level security work.

REPOSITORY FINDING	SEVERITY	OBSERVED STATUS
Overly broad permissions in GitHub Actions workflow	Medium	New in screenshot
Improper Access Control	Medium	PR Open at that stage
Improper Input Validation	Medium	PR Open at that stage
Exposure of Sensitive Information	Low	PR Open at that stage
actions/checkout persists Git credentials in workflow	Low	Later shown Solved

Repositories > mishipass

mishipass 5 issues

Your lockfile is missing some information
We were unable to analyze dependencies in this repository due to missing lockfiles.

Search All types Actions

Type	Name	Severity	Location	Fix time	Status
(all)	Overly Broad Permissions in GitHub Actions Workflows is risky in dependabot-automerge.yml	Medium	mishipass	30 min	New
(*)	Improper Access Control apps/worker/src/db/repositories/missingAlerts.ts	Medium	mishipass	2 hr	PR Open →
(*)	Improper Input Validation apps/worker/src/routes/transferRequests.ts	Medium	mishipass	6 hr	PR Open →
(*)	Exposure of Sensitive Information apps/worker/src/routes/auth.ts	Low	mishipass	4 hr	PR Open →
(all)	GitHub Action actions/checkout persist Git credentials in workflow in pages.yml, codeql.yml and 1 others	Low	mishipass	15 min	New

We have no more issues to show

Figure 9. Repository scan showing five issues across application and GitHub Actions configuration.

5.1 Verified solved workflow issue

The later repository screenshot, filtered to solved issues, shows the GitHub Actions checkout credential-persistence finding with status Solved. The page also indicates that issues were solved that day.

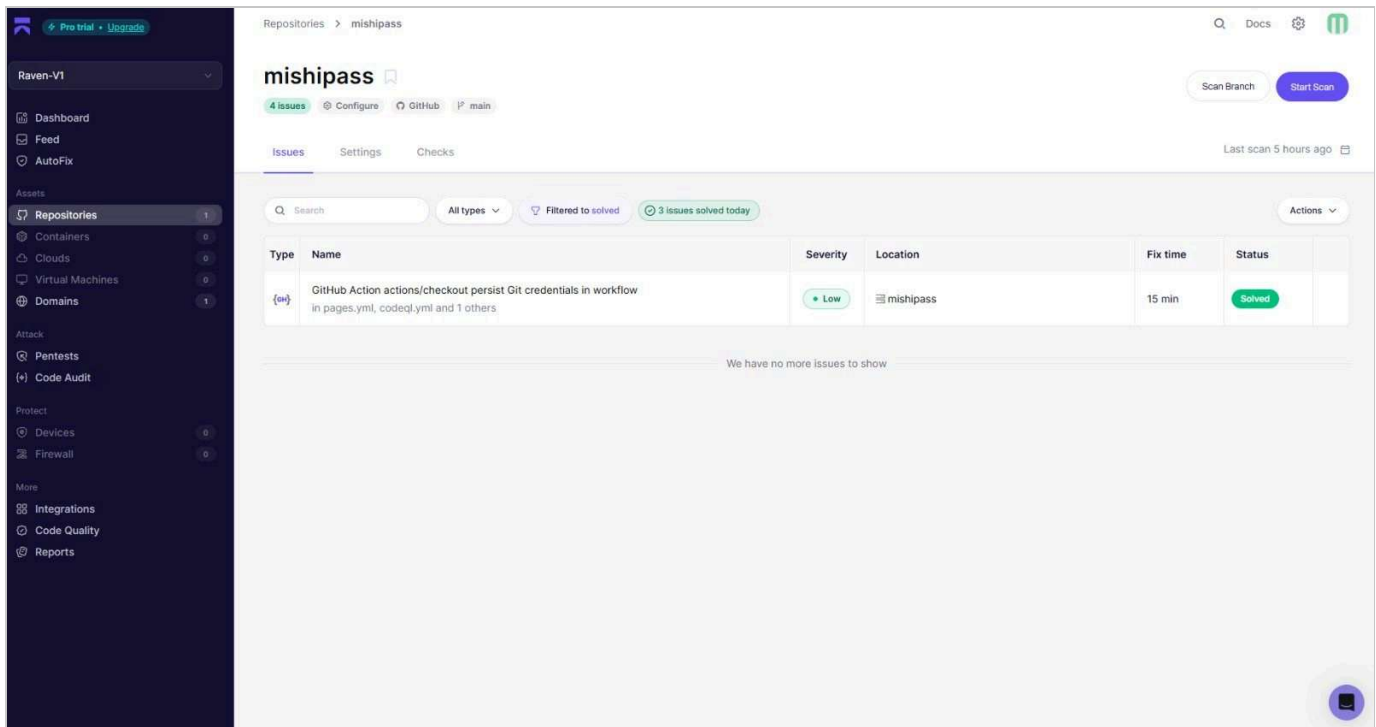


Figure 10. GitHub Actions credential-persistence finding shown as Solved.

6. Live Domain Security Scan

The deployed MishiPass endpoint was also scanned. The latest captured domain evidence still shows 3 open HTTP response-header issues.

FINDING	SEVERITY	WHY IT MATTERS	REQUIRED ACTION
Content Security Policy header not set	Critical	Reduces protection against XSS and unauthorized content execution	Add a tested CSP and rescan
HSTS header is missing	High	Does not enforce future HTTPS-only access in supporting browsers	Add Strict-Transport-Security and rescan
Missing anti-clickjacking header	Medium	Allows framing unless protected by policy	Use CSP frame-ancestors and/or X-Frame-Options

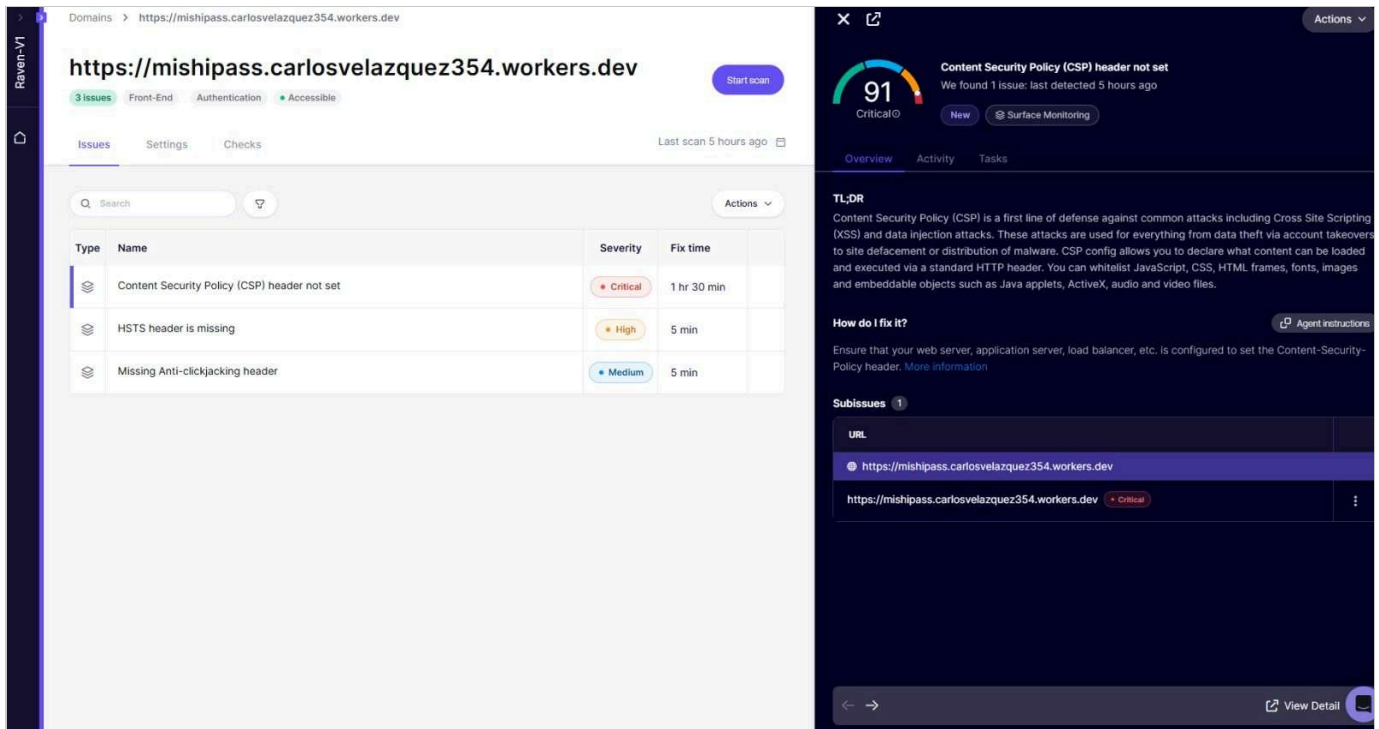


Figure 11. Live-domain scan showing CSP, HSTS and anti-clickjacking findings.

ACTION Do not submit this as a clean domain scan yet — the latest evidence still shows these three deployment-level issues. Fix them, start a new domain scan, and capture the refreshed clean or improved result.

7. Current Status and Required Final Actions

Based on the screenshots provided, the security work is advanced but the evidence is not yet in its strongest submission-ready state. The fixes appear to have been merged, but final verification has not been reflected in the Aikido Code Audit summary, and the live-domain scan still contains three open findings.

1 Retest the AI Code Audit

Open the audit, use the free Retest action, wait for completion, and confirm the merged findings move to Solved/Resolved.

2 Recheck repository issues

Run or refresh the repository scan on the final main branch and confirm the latest issue count.

3 Fix live security headers

Add and verify CSP, HSTS, and anti-clickjacking protection without breaking the application.

4 Rescan the production domain

Start a fresh domain scan after deployment and capture the final result.

5 Capture final screenshots

Take one clear screenshot each of the final Code Audit summary, repository status, and live-domain status.

6 Submit the evidence

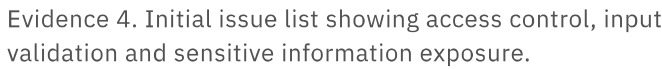
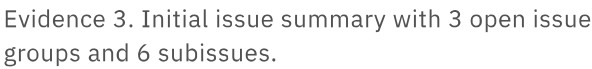
Use this report, replacing the current-status screenshots with the final retest screenshots if the results change.

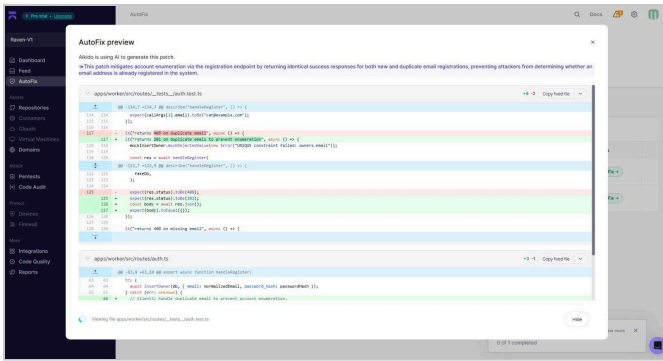
Submission-ready final statement

FINAL — USE ONLY AFTER THE FINAL RETEST

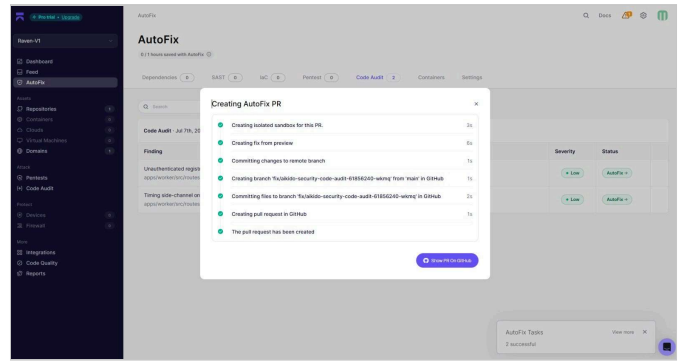
“MishiPass was reviewed with Aikido Security across source code, repository configuration, CI/CD workflows, and the deployed application. Findings were remediated, merged, retested, and documented with scan evidence. The final report includes the before-and-after security results and the resolved issues.”

The following appendix preserves all 24 screenshots from the uploaded evidence deck in chronological order. The captions describe the visible stage of the audit without claiming more than the screenshots prove.

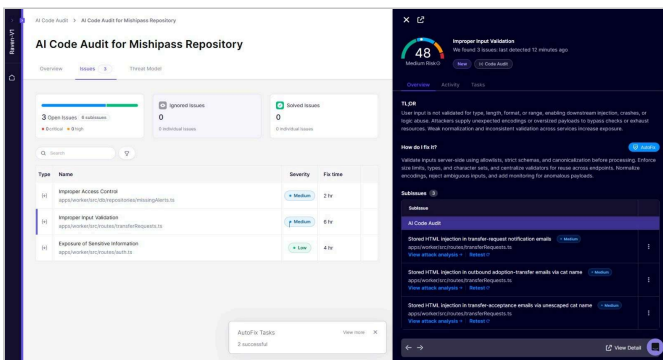




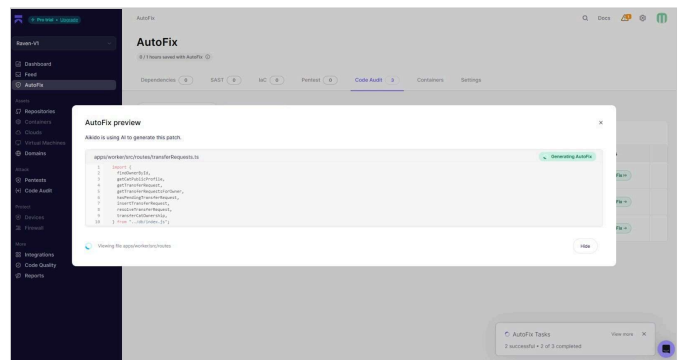
Evidence 7. Generated AutoFix code diff.



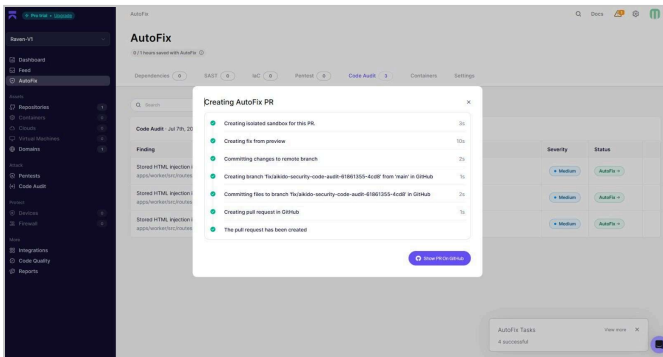
Evidence 8. AutoFix task execution progress.



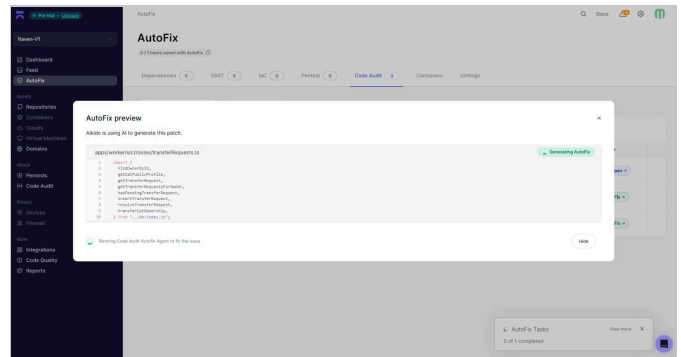
Evidence 9. Audit issue overview with additional detail panel.



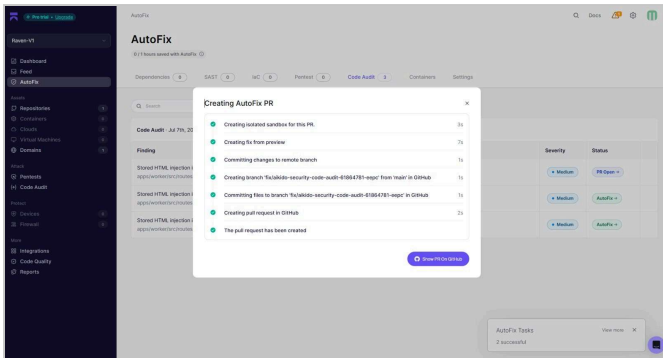
Evidence 10. Additional AutoFix preview.



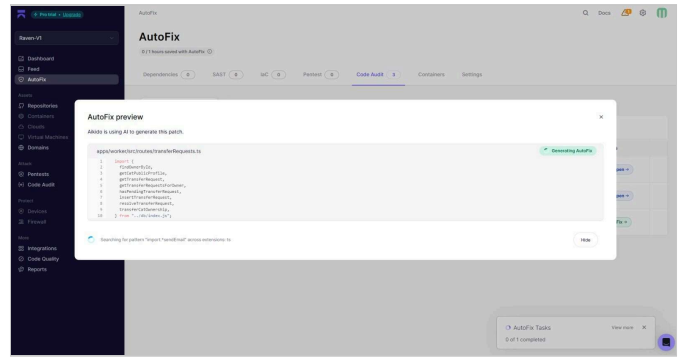
Evidence 11. Additional AutoFix task execution.



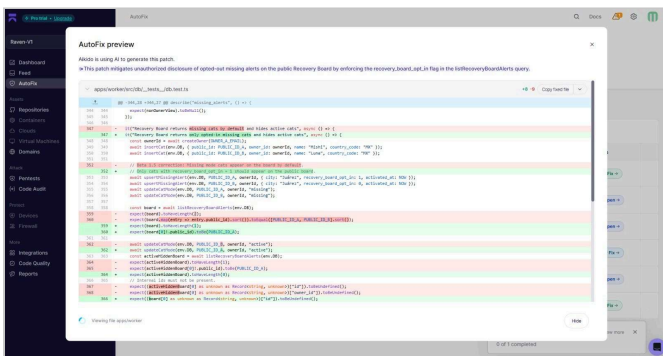
Evidence 12. Additional AutoFix preview.



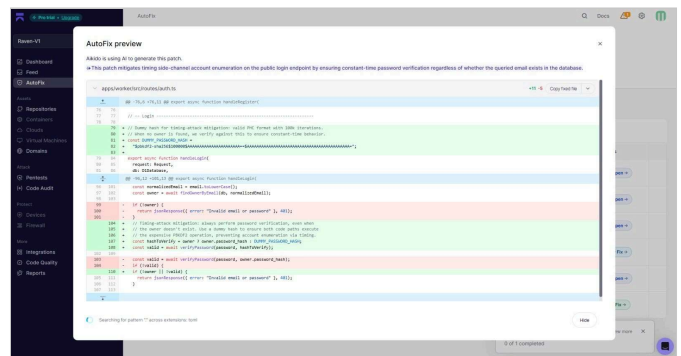
Evidence 13. Additional AutoFix task execution.



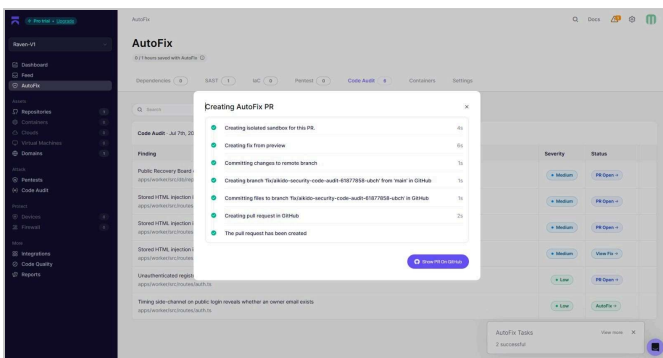
Evidence 14. Additional AutoFix preview.



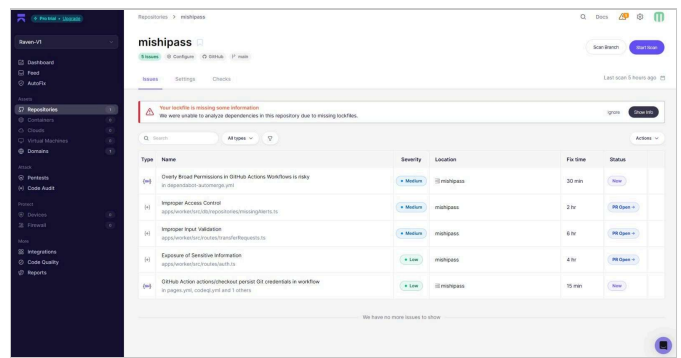
Evidence 15. Generated AutoFix code changes.



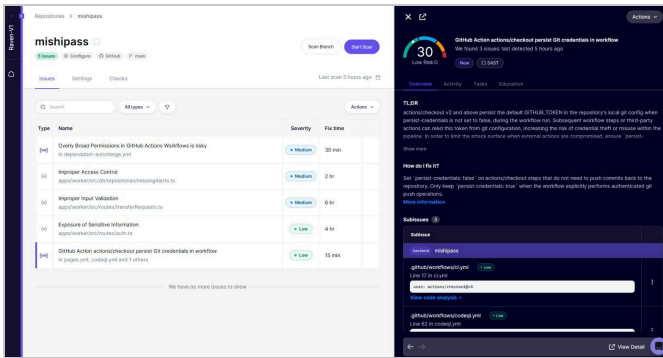
Evidence 16. Generated AutoFix code changes for another finding.



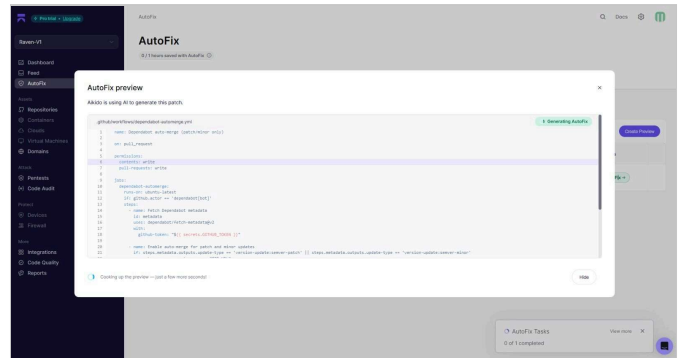
Evidence 17. AutoFix task execution during the remediation cycle.



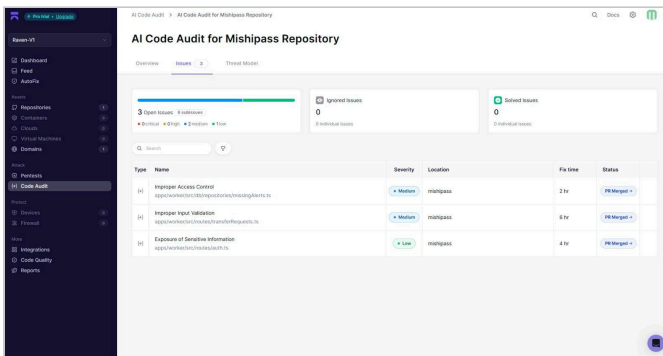
Evidence 18. Repository scan showing five issues.



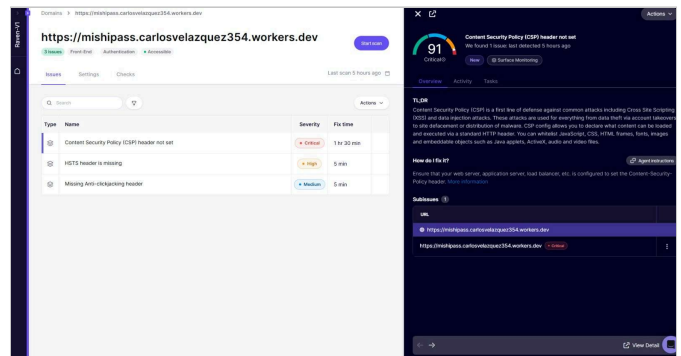
Evidence 19. GitHub Actions credential-persistence finding detail.



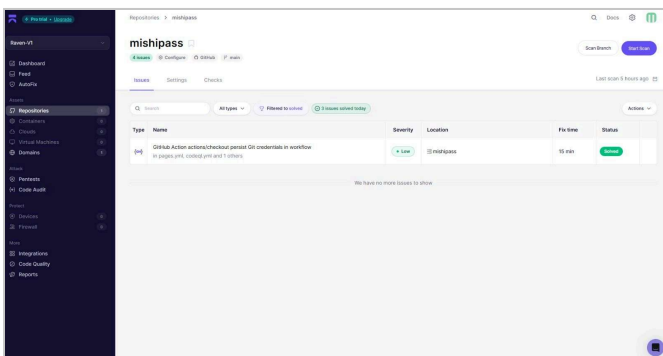
Evidence 20. AutoFix preview for a workflow-related issue.



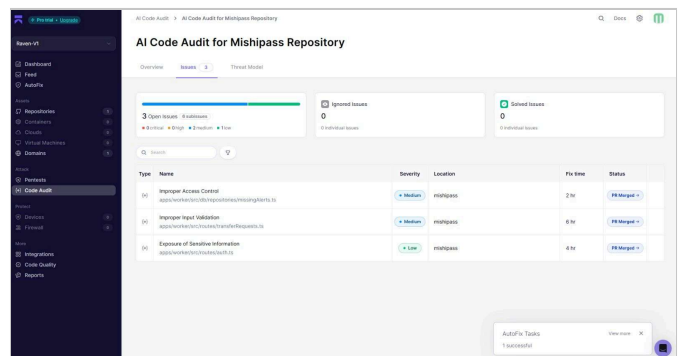
Evidence 21. Code-audit findings shown with PR Merged status.



Evidence 22. Live-domain scan showing three HTTP security-header issues.



Evidence 23. Repository workflow credential issue shown as Solved.



Evidence 24. Latest code-audit screenshot: PRs merged, but summary still shows 3 open and 0 solved.

Appendix B. Evidence Interpretation Statement

This report was prepared from the 24 screenshots supplied in the Aikido evidence deck. It intentionally distinguishes between a fix being generated, a pull request being merged, a finding being marked solved, and a scan being re-tested. This prevents the project report from overstating the security status.

At the time represented by the final screenshot, the AI Code Audit still displayed 3 open issues and 0 solved issues even though all three rows were labeled PR Merged. Therefore, the correct next step is to run Aikido Retest and capture the refreshed result.

The domain scan evidence also displayed three open deployment-level findings: missing CSP, missing HSTS, and missing anti-clickjacking protection. These should be addressed and rescanned before the strongest possible hackathon submission.

